

Chapter - Security

Properties/Principles of Secure Software

1. Confidentiality
2. Integrity
3. Authentication
4. Non-repudiation
5. Availability

Security Principles

1. Confidentiality

Definition:

Confidentiality is a security principle that ensures ***information is accessible only to authorized users.*** It prevents sensitive information from being disclosed to unauthorized parties.

Violation Scenario:

1. A student's GPA is visible to other students without permission.
2. An exam question paper is leaked before the exam starts.

---

2. Integrity

Definition:

Integrity ensures that ***data can only be modified by authorized users.*** It protects information from unauthorized alteration or damage.

Violation Scenario:

1. A student changes his marks directly in the university database.
2. A hacker modifies a student's submitted assignment without permission.

---

3. Authentication

Definition:

Authentication is the process of ***verifying the identity of a user or entity*** before allowing access to a system.

Violation Scenario:

1. A hacker accesses a student's account using a stolen password.
2. An unauthorized person logs into an instructor's account.

---

4. Non-Repudiation

Definition:

Non-repudiation ensures that ***a user cannot deny performing an action*** when proper evidence exists.

Violation Scenario:

1. A student edits a submission after the deadline but denies doing it.
2. An employee deletes company data but claims they did not perform the action.

---

5. Availability

Definition:

Availability ensures that ***authorized users can access system resources whenever needed.*** A system should remain responsive and accessible.

Violation Scenario:

1. A university website becomes unavailable during registration due to a DoS attack.
2. A banking system goes offline due to a server attack.

Cyber Attacks Classification

i. Malware Attacks

Unwanted software that is installed on system without consent.

Types of Malware:

a) Ransomware

Definition:

Ransomware is a type of malware that ***locks/encrypts user data*** and demands money ***(ransom)*** to restore access.

Scenario:

1. A company’s important files become encrypted, and attackers demand payment to unlock them.
2. A user cannot access personal documents because ransomware has locked the files.

Safety Measure:

- Keep regular backups.
- Avoid suspicious downloads and links.

---

b) Spyware

Definition:

Spyware is a malicious program that ***secretly collects confidential information about users.***

Scenario:

1. Spyware secretly collects a user's browsing history and personal data.

2. A spyware program steals banking information from a user's computer.

Safety Measure:

- Use antivirus software.
- Install applications only from trusted sources.

---

c) Trojan Horse

Definition:

A Trojan Horse is a malicious program that ***looks like a legitimate application but contains harmful intentions.***

Scenario:

1. A user downloads a fake game, but it secretly installs malware.
2. A fake software update gives attackers access to the system.

Safety Measure:

- Download software from official sources.
- Avoid opening unknown files.

---

d) Logic Bomb

Definition:

A Logic Bomb is a malicious program that ***remains inactive until a specific time or condition triggers it.***

Scenario:

1. A program activates on a specific date and deletes company files.
2. A malicious code activates when a particular employee account is removed.

Safety Measure:

- Perform regular security audits.
- Monitor suspicious programs.

---

ii. Password Attacks

(**Attacks targeting user passwords**)

These attacks try to steal or guess passwords.

a) Brute Force / Dictionary Attack

Definition:

A Dictionary Attack is a password attack where ***attackers try common passwords*** from a prepared list to find the correct password.

Scenario:

1. An attacker tries passwords like "123456", "password", etc.
2. A hacker uses a password list to repeatedly attempt login.

Safety Measure:

- Use strong passwords.
- Enable ***multi-factor authentication.***

---

b) Phishing

Definition:

Phishing is an attack where attackers ***send fake but attractive emails/messages*** to trick users into revealing information.

Scenario:

1. A fake bank email asks the user to login and steals credentials.
2. A fake university email asks students for their password.

Safety Measure:

- Avoid suspicious links.
- Verify email sources.

---

c) Man-in-the-Middle (MITM)

Definition:

MITM is an attack where an attacker secretly intercepts communication between two parties and captures data packets.

Scenario:

1. A hacker ***captures login information from public WiFi.***
2. An attacker modifies communication between a user and a website.

Safety Measure:

- Use ***HTTPS.***
- Use encrypted communication.

---

d) Credential Stuffing

Definition:

Credential stuffing is an attack where ***attackers use stolen username-password combinations*** from one service to access another service.

Scenario:

1. A leaked Facebook password is used to access Gmail.
2. Stolen credentials from a data breach are used on another website.

Safety Measure:

- Use unique passwords.
- Enable MFA.

---

e) Keylogger

Definition:

A keylogger is a malicious program ***that records keyboard input to steal passwords*** and sensitive information.

Scenario:

1. A keylogger records a user's banking password while typing.
2. A keylogger captures personal messages typed by a user.

Safety Measure:

- Avoid unknown software.
- Use updated antivirus.

---

f) Social Engineering

Definition:

Social Engineering is an attack where ***attackers manipulate people into revealing passwords*** or confidential information.

Scenario:

1. An attacker pretends to be IT support and asks for a password.
2. Someone tricks a user by pretending to be a trusted person.

Safety Measure:

- Never share passwords.
- Verify identity before sharing information.

---

iii. Injection Attack

SQL Injection

Definition:

SQL Injection is a ***code injection attack where attackers insert malicious SQL statements*** through user input to manipulate a database.

Scenario:

1. An attacker enters malicious SQL code in a login form and bypasses authentication.
2. An attacker modifies or deletes database records using SQL commands.

Safety Measure:

- ***Use SQL parameters/prepared statements.***

- Validate user input.

---

iv. Vulnerability Exploitation Attack

Zero Day Attack

Definition:

A Zero Day Attack exploits a newly discovered vulnerability before developers release a patch.

Scenario:

1. A hacker discovers a software vulnerability before the developer knows about it.
2. Users ignore updates, allowing attackers to exploit old vulnerabilities.

Safety Measure:

- Update software regularly.
- Install security patches immediately.